

Sociotechnical Security

CS 8803/4803

Professor Veronica Rivera

Lecture 6 – Authentication II (Solution approaches)



Last time

1. **Problematize:** Show the status-quo is bad
 1. Quantitative metrics are typically stronger
 2. But qualitative work is often needed to know what to measure
2. **Model:** Build a better model of human behavior
3. **Fix:** Design a better system to fix the status quo using this model

Today

1. **Problematize:** Show the status-quo is bad
 1. Quantitative metrics are typically stronger
 2. But qualitative work is often needed to know what to measure
2. **Model:** Build a better model of human behavior
3. **Fix:** Design a better system to fix the status quo using this model
 1. Evaluate potential solutions and refine your model

Recall: Humans are bad at passwords

1. Weak passwords
2. Shared passwords
3. Phishing (giving passwords to the adversary)

Password Policies

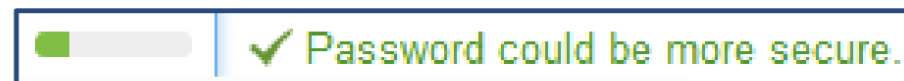
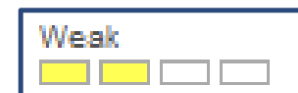
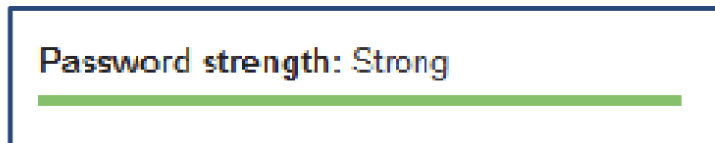
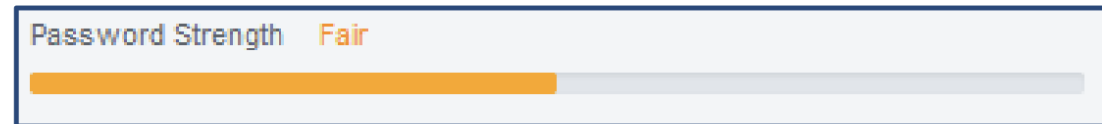
- Old recommendation:
 - 7 or 8 characters, at least 3 out of {digits, upper-case, lower-case, non-alphanumeric}, no dictionary words, change every 4 months, password may not be similar to previous 12 passwords...
- **But** ... results in frustrated users and less security
 - Burdens of devising, learning, forgetting passwords
 - Users construct passwords insecurely, write them down
 - Can't use their favorite password construction techniques (small changes to old passwords, etc.)
 - Heavy password re-use across systems
 - (Password managers can help)

“New” (2017) NIST Guidelines 😊

- Remove requirement to periodically change passwords
- Screen for commonly used passwords
- Allow copy-paste into password fields
 - But concern: what apps have access to clipboard?
- Allow but don't require arbitrary special characters
- Etc.

<https://pages.nist.gov/800-63-3/sp800-63b.html>

Password meters



Other options?

- Password managers
 - Examples: LastPass, KeePass, built into browsers
 - Can have security vulnerabilities...
- Two-factor authentication
 - Leverage phone (or other device) for authentication
- Hardware tokens
 - Examples: YubiKey, RSA SecurID
- Add biometrics
 - For example, keystroke dynamics or voiceprint
- Passkeys

Password managers

- Password manager = vault + generator
- For each site, generator creates a password that is stored in vault
- User creates and remembers single password (master password) to open the vault
- Master password is stretched into a symmetric encryption key
- Password manager encrypts vault and syncs encrypted vault across devices



Password managers

+ Pros

- Backward compatible
- Strong, unique passwords
- Phishing resistant

– Cons

- Single master password
- Third-party reliance (availability)

Bottom line: unique generated passwords beat reuse — just protect the master password.

Example breach: LastPass

- 2022
- LastPass operations engineer's computer gets hacked
- Hackers get his credentials
- Break into LastPass servers
- Steal ~30 encrypted vaults
- This does not immediately reveal user passwords!
 - An offline brute-force attack is needed
 - Slowed by LastPass's use of a KDF
- Does lead to some hacks of user accounts, eventually

LastPass...

Dear valued customer,

We are writing to inform you that we recently detected some unusual activity within portions of the LastPass development environment. We have determined that an unauthorized party gained access to portions of the LastPass development environment through a single compromised developer account and took portions of source code and some proprietary LastPass technical information. We have no evidence that this incident involved any access to customer

Two-factor authentication (TOTP)

- Many different types: SMS OTP, TOTP, push-based
- Physical device (phone) running an app that holds a shared cryptographic secret
- At enrollment, symmetric secret is shared between authenticator app and site server
- At login:
 - App reads current time from device
 - App computes a one-way hash combining the secret with the current 30-second time window
 - User types code into login page
 - Server computes same hash and checks if results match



Two-factor authentication (TOTP)

+ Pros

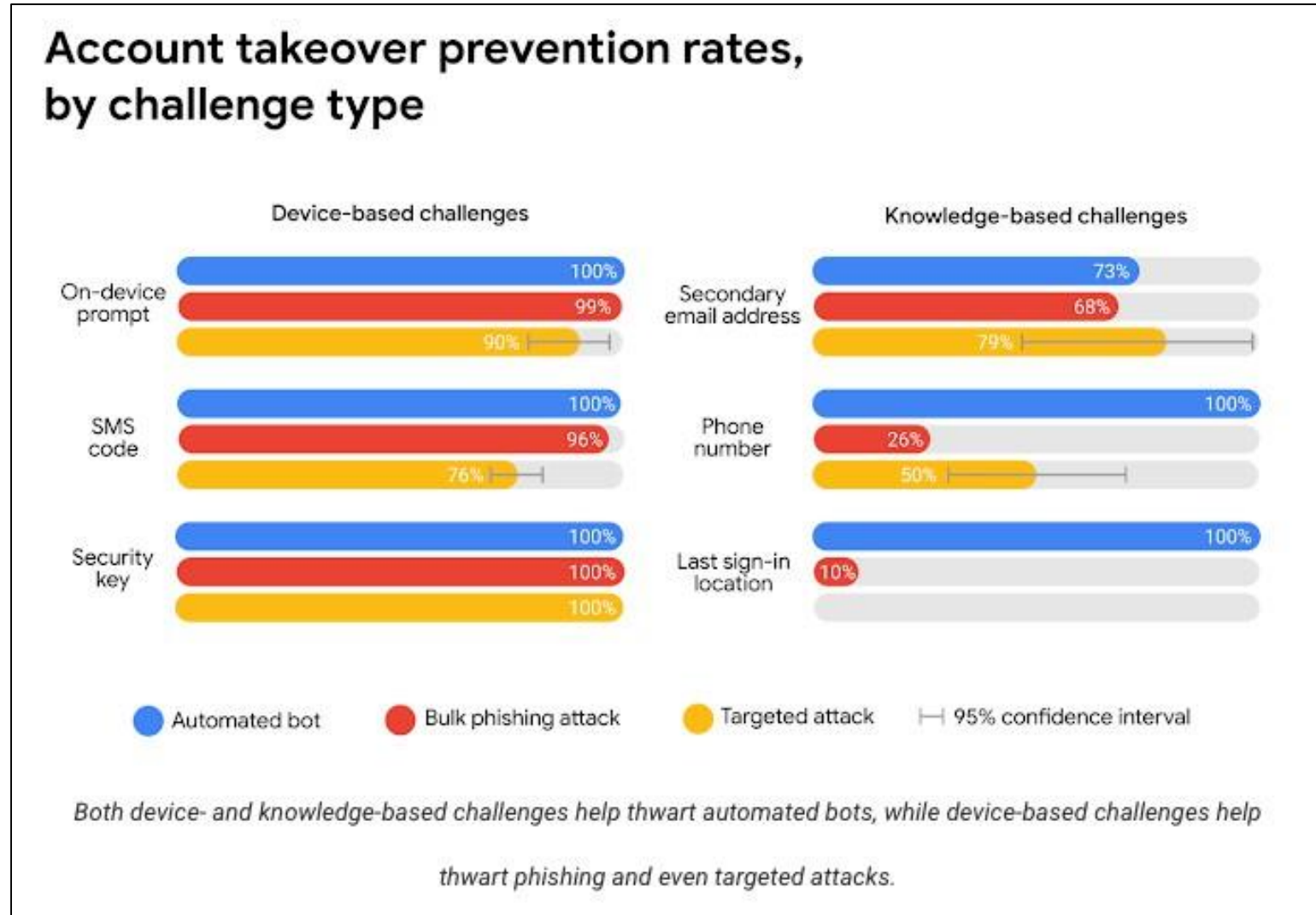
- Very phishing resistant (codes expire in ~60 seconds)
- Technology-flexible: phone, email, or hardware token

– Cons

- Still have a password
- Have to carry a device

Bottom line: a practical upgrade for almost any system, but it layers on top of passwords rather than replacing them.

Secondary Factors Do Help!



Hardware tokens (key-based)

- Physical device that creates & shares cryptographic keys
- For each site, token generates unique keypair
 - Site is defined by origin: scheme, hostname, port (scheme://host:port → <https://google.com> vs. <https://calendar.google.com>)
- At login:
 - Site server sends random cryptographic string to browser
 - Bundle: Browser packages this with origin
 - User physically interacts with token
 - Token signs bundle with private key
 - Server verifies signature against public key
- Signature produced for one site is cryptographically useless on another



Hardware tokens (key-based)

+ Pros

- Phishing-proof
- No more password

– Cons

- Reliance on a physical device
- Hard to upgrade

Bottom line: the strongest option available — as long as users keep (and can replace) the key.

Recall: Many Ways to Prove Who You Are

- “Something you know”
 - Passwords
 - Answers to questions that only you know
- “Something you have”
 - Secure tokens, mobile devices
- “Something you are”
 - Biometrics

Biometrics



- Unique identifying characteristics used to authenticate a user
- Biological and physiological
 - Fingerprints, iris scan
- Behavioral: how you perform actions
 - Handwriting, typing, gait
- Physical sensor → mathematical template of some biological characteristic stored locally
- At login:
 - Fresh sample of characteristic is converted and compared to stored sample
 - Match score computed
 - If high enough, device grants access

Biometrics

+ Pros

- Nothing to remember
- Passive — no user effort
- Can't be shared (generally)
- Potentially highly unique

– Cons

- Not secret (e.g., prints on glass)
- Revocation is difficult (impossible?)
- Not always **that** unique
- Relies on sensor hardware

Bottom line: convenient and password-free, but you cannot reset a fingerprint once it fails or leaks.

US Law and Biometrics

- Circuit splits on what 5th amendment covers.
- Broadly: some biometrics (e.g. face unlock) may *not* be protected
 - Some biometrics (e.g. fingerprint) *might* be protected
- Passcodes *are* protected

Passkeys

- New term [2022; Apple/Google/MS]
 - A marketing term for the WebAuthn/FIDO2 authentication standard
- An umbrella for auth. technology combining three things:
 - A (sk, pk) pair
 - user does not generate a password!
 - **sk never leaves the user's device** unencrypted
 - Used in a **site-specific** authentication protocol
 - Prevents phishing
 - Stored in a **locked vault** (fingerprint, face, pin, or password)
 - Example 1: phone with fingerprint/pin
 - Example 2: "password" manager with master password

Passkeys

+ Pros

- Phishing-proof
- Single-factor
- No password/just a pin

– Cons

- Need a recovery system, somewhere
- Could be confusing for users to understand

Bottom line: great! Use them. But also there may be usability challenges that still to be understood

Discussion

Warm up question: Bonneau et al. evaluated various authentication schemes using a set of usability, deployability, and security benefits. What did they not evaluate across these three categories that might also be important? This could be other benefits within these three categories, but also maybe other categories that extend their UDS framework.

Next time:

- Phishing and social engineering on Wednesday
- Project proposals due Wednesday
- If you are leading discussion next week, your slides and questions are due this week
 - Assignment is open on Gradescope now and will remain open until Nov. 18
 - Please submit by 2 PM on due date listed for your name to avoid late penalties! [Discussion assignments](#)